



Orviohub Organization and Billing Checklist

Use this as a master implementation checklist. The organization is the business container, while billing belongs to the organization or billing account—not to individual staff members. Workspace members receive access through membership and permissions without purchasing separate subscriptions.^[1]

1. Core Architecture

Account and organization structure

- ☐ One central Orviohub user account exists.
- ☐ Users can own organizations.
- ☐ Users can join organizations owned by others.
- ☐ Users can have different roles in different organizations.
- ☐ Organization and workspace use one consistent concept.
- ☐ Personal account data is separated from organization data.
- ☐ Organization data is separated from application data.
- ☐ Application data is separated from branch data.
- ☐ Every organization-owned record contains `workspaceId`.
- ☐ Every application-owned record contains `workspaceId` and `productKey`.
- ☐ Every branch-owned record contains `workspaceId` and `branchId`.
- ☐ Tenant context is resolved server-side.
- ☐ Client-submitted workspace IDs are never trusted without authorization checks.
- ☐ Client-submitted roles and permissions are never trusted.
- ☐ Cross-organization data access is rejected.

Application availability

- ☐ Inventory is the only user-facing application in the MVP.
- ☐ Future applications remain in the internal application registry.
- ☐ Future applications are hidden from regular users.
- ☐ Future applications cannot be activated by regular users.
- ☐ Future applications do not appear in onboarding.

- ☐ Future applications do not appear in the application launcher.
- ☐ Future application routes are protected.
- ☐ Superadmin can view future applications internally.
- ☐ Application availability is controlled by backend status or feature flags.

2. Organization Creation

Eligibility

- ☐ Backend checks whether the user can create an organization.
- ☐ Ownership limit is enforced server-side.
- ☐ Free Trial limit is enforced server-side.
- ☐ Joined organizations do not consume ownership slots.
- ☐ Archived organizations follow an explicit counting policy.
- ☐ Suspended organizations follow an explicit counting policy.
- ☐ Superadmin override is permission-controlled.
- ☐ Eligibility checks do not create unnecessary audit noise.
- ☐ Eligibility responses include current usage and limits.
- ☐ Concurrent creation requests are handled safely.
- ☐ Duplicate creation requests are prevented with idempotency.

Current limits

- ☐ Maximum owned organizations is defined.
- ☐ Maximum Free Trial organizations is defined.
- ☐ Joined organizations are not counted as owned organizations.
- ☐ Plan-based limits are stored as configuration or entitlements.
- ☐ Limit errors return a consistent error code.
- ☐ Limit errors preserve submitted form data.
- ☐ Limit errors show a clear upgrade option.

Organization creation fields

- ☐ Organization name.
- ☐ Organization slug.
- ☐ Organization type.
- ☐ Business category.
- ☐ Country.

- ☐ State.
- ☐ City.
- ☐ Timezone.
- ☐ Currency.
- ☐ Business phone.
- ☐ Business email.
- ☐ Address.
- ☐ Logo.
- ☐ Business description.

Defaults

- ☐ Default country is configured.
- ☐ Default currency is configured.
- ☐ Default timezone is configured.
- ☐ Default organization type is configured.
- ☐ Default status is `creating`.
- ☐ Default settings are created.
- ☐ Default roles are created.
- ☐ Inventory is selected as the only available application.
- ☐ Primary Inventory branch is created.
- ☐ Owner membership is created.
- ☐ Organization onboarding flow is created.

Creation transaction

- ☐ Organization record is created.
- ☐ Billing account is created.
- ☐ Subscription context is created.
- ☐ Owner membership is created.
- ☐ Default settings are created.
- ☐ Default roles are created.
- ☐ Inventory application record is created.
- ☐ Primary branch is created.
- ☐ Onboarding flow is created.
- ☐ Audit event is written.
- ☐ Welcome notification is sent.

- [] Operation is idempotent.
- [] Partial failures can be resumed or safely rolled back.
- [] No duplicate owner memberships are created.
- [] No duplicate billing accounts are created.
- [] No duplicate primary branches are created.

The workspace plan explicitly requires organization creation to initialize the workspace, owner membership, settings, roles, product entitlements, onboarding, audit event, and notification as one reliable flow.^[2]

3. Organization Lifecycle

- [] `creating` status exists.
- [] `setup_incomplete` status exists.
- [] `trial` status exists.
- [] `active` status exists.
- [] `past_due` status exists.
- [] `suspended` status exists.
- [] `archived` status exists.
- [] `deleting` status exists.
- [] `deleted` status exists.
- [] Valid status transitions are defined.
- [] Invalid status transitions are rejected.
- [] Status changes are audited.
- [] Status changes notify authorized users.
- [] Suspended organizations cannot perform restricted actions.
- [] Archived organizations preserve historical data.
- [] Deleted organizations follow a documented retention policy.
- [] Deletion does not remove legally required billing or audit records.
- [] Active sessions are revoked when required.
- [] Product access is recalculated after status changes.

4. Organization Settings

General

- ☐ Organization name can be viewed.
- ☐ Organization name can be edited by authorized users.
- ☐ Organization slug can be viewed.
- ☐ Organization slug uniqueness is enforced.
- ☐ Slug changes are audited.
- ☐ Organization type can be viewed.
- ☐ Business category can be viewed.
- ☐ Business description can be edited.
- ☐ Organization status is visible.
- ☐ Created and updated timestamps are visible.

Contact and address

- ☐ Business phone is optional.
- ☐ Business email is optional.
- ☐ Business phone is normalized.
- ☐ Business email is normalized.
- ☐ Business address is separate from user address.
- ☐ Business address is separate from branch addresses.
- ☐ Business phone verification is optional by default.
- ☐ Business phone can be verified if used for billing or official communication.
- ☐ Contact changes are audited.
- ☐ Authorized administrators can manage organization contact details.
- ☐ Ordinary members cannot change organization contact details.

Branding

- ☐ Organization logo can be uploaded.
- ☐ Logo file type is validated.
- ☐ Logo file size is limited.
- ☐ Executable uploads are rejected.
- ☐ Logo preview is supported.
- ☐ Logo replacement is supported.
- ☐ Logo removal is supported.
- ☐ Logo is usable on receipts.
- ☐ Logo is usable on invitations.

- ☐ Logo is usable in application headers.
- ☐ Logo upload and deletion are audited.
- ☐ Private storage credentials are not exposed.

Localization

- ☐ Currency can be configured.
- ☐ Timezone can be configured.
- ☐ Country can be configured.
- ☐ Date format can be configured.
- ☐ Number format can be configured.
- ☐ Default language can be configured.
- ☐ Currency changes are restricted after financial records exist.
- ☐ Currency changes require confirmation.
- ☐ Historical transactions retain their original currency.
- ☐ User display currency does not change organization transaction currency.

Notifications

- ☐ Workspace notification preferences exist.
- ☐ Billing notification preferences exist.
- ☐ Inventory notification preferences exist.
- ☐ Member-change notifications exist.
- ☐ Low-stock notifications exist.
- ☐ Payment failure notifications exist.
- ☐ Security notifications cannot be fully disabled.
- ☐ Billing notifications go to the owner or billing managers by default.
- ☐ Notification changes are audited.

5. Membership and Permissions

Organization membership

- ☐ Organization membership table exists.
- ☐ Membership has a status.
- ☐ Membership can be active.
- ☐ Membership can be suspended.
- ☐ Membership can be removed.

- ☐ Membership has a role.
- ☐ Membership has joined date.
- ☐ Membership has invitation metadata.
- ☐ Removed members lose access.
- ☐ Removed members' historical business records remain.
- ☐ Removed members' relevant sessions can be revoked.
- ☐ Organization must always have at least one owner.
- ☐ Only owner cannot remove themselves.
- ☐ Ownership transfer requires confirmation.
- ☐ Ownership transfer requires re-authentication.
- ☐ Ownership transfer is audited.

Organization roles

- ☐ Owner role exists.
- ☐ Workspace Admin role exists.
- ☐ Workspace Manager role exists.
- ☐ Workspace Member role exists.
- ☐ Workspace Viewer role exists.
- ☐ Roles are permission-based.
- ☐ Role changes are audited.
- ☐ Role changes require appropriate permission.
- ☐ Role changes cannot create an ownerless organization.

Organization permissions

- ☐ `workspace.view`.
- ☐ `workspace.update`.
- ☐ `workspace.manage_members`.
- ☐ `workspace.manage_roles`.
- ☐ `workspace.manage_applications`.
- ☐ `workspace.manage_billing`.
- ☐ `workspace.manage_settings`.
- ☐ `workspace.view_audit`.
- ☐ `workspace.export_data`.
- ☐ `workspace.archive`.
- ☐ `workspace.delete`.

Application access

- ☐ Organization membership does not automatically grant Inventory access.
- ☐ Inventory membership is separate.
- ☐ Inventory role is separate.
- ☐ Branch access is separate.
- ☐ Product access is checked server-side.
- ☐ Suspended product membership blocks access.
- ☐ Removed product membership blocks access.
- ☐ Future application access cannot be created in the MVP.

6. Inventory Application

- ☐ Inventory is registered as available.
- ☐ Inventory is visible to users.
- ☐ Inventory is activatable.
- ☐ Inventory activation checks billing entitlement.
- ☐ Inventory activation checks organization status.
- ☐ Inventory activation checks membership.
- ☐ Inventory activation checks application limits.
- ☐ Inventory activation creates an application record.
- ☐ Inventory activation creates an onboarding flow.
- ☐ Inventory activation creates or confirms a primary branch.
- ☐ Inventory activation creates an audit event.
- ☐ Inventory activation sends a notification.
- ☐ Inventory can be suspended.
- ☐ Inventory can be restored.
- ☐ Inventory onboarding can be resumed.
- ☐ Inventory onboarding status is visible to the owner.
- ☐ Inventory application settings are separate from organization settings.
- ☐ Inventory application permissions are explicit.

Inventory roles

- ☐ Inventory Owner.
- ☐ Inventory Manager.
- ☐ Sales Attendant.

- [] Stock Manager.
- [] Accountant.
- [] Inventory Viewer.

Inventory permissions

- [] inventory.view.
- [] inventory.manage_products.
- [] inventory.view_stock.
- [] inventory.receive_stock.
- [] inventory.adjust_stock.
- [] inventory.record_sales.
- [] inventory.cancel_sales.
- [] inventory.process_returns.
- [] inventory.view_cost.
- [] inventory.view_profit.
- [] inventory.view_reports.
- [] inventory.export_data.
- [] inventory.manage_members.
- [] inventory.manage_branch_access.
- [] inventory.manage_settings.

7. Branches

Branch structure

- [] Branch belongs to an organization.
- [] Branch belongs to Inventory for the MVP.
- [] Branch has a unique ID.
- [] Branch has a name.
- [] Branch has a code.
- [] Branch has an address.
- [] Branch has a phone.
- [] Branch has an email.
- [] Branch has a manager, if assigned.
- [] Branch has a status.
- [] Branch has a primary indicator.

- ☐ Branch has created and updated timestamps.
- ☐ Branch queries are organization-scoped.
- ☐ Branch queries are Inventory-scoped.

Branch rules

- ☐ Primary branch is automatically created.
- ☐ Free Trial branch limit is enforced.
- ☐ Standard branch limit is enforced.
- ☐ Branch limit is checked server-side.
- ☐ At least one active primary branch remains.
- ☐ Primary branch cannot be archived without replacement.
- ☐ Branch code is unique within the organization.
- ☐ Branch archive preserves historical records.
- ☐ Branch deletion is disabled or restricted in the MVP.
- ☐ Branch status changes are audited.
- ☐ A user cannot access an unauthorized branch.
- ☐ A branch cannot be created in another organization.

Branch membership

- ☐ Branch members are separate from organization members.
- ☐ Branch role is stored.
- ☐ Branch permissions are stored.
- ☐ Branch access can be granted.
- ☐ Branch access can be suspended.
- ☐ Branch access can be removed.
- ☐ Branch transfers are supported.
- ☐ Branch transfer history is stored.
- ☐ Branch member changes are audited.
- ☐ Removing branch access does not remove organization membership.
- ☐ Removing branch access does not delete business history.

8. Free Trial

- ☐ Free Trial plan exists.
- ☐ Free Trial duration is defined.
- ☐ Free Trial eligibility is checked.
- ☐ User cannot create multiple trial organizations beyond the limit.
- ☐ Free Trial requires no payment.
- ☐ Free Trial creates a trial subscription.
- ☐ Free Trial creates trial entitlements.
- ☐ Trial start date is stored.
- ☐ Trial end date is stored.
- ☐ Trial status is visible to the owner.
- ☐ Trial ending notifications are sent.
- ☐ Trial limits are enforced.
- ☐ Trial usage is visible.
- ☐ Trial can be upgraded to Standard.
- ☐ Trial expiration does not delete data.
- ☐ Trial expiration does not delete branches.
- ☐ Trial expiration does not delete users.
- ☐ Trial expiration creates an audit event.
- ☐ Expired trial enters a documented restricted state.
- ☐ Existing data remains viewable according to policy.
- ☐ Upgrade prompts are clear and contextual.

Free Trial entitlements

- ☐ One owned organization.
- ☐ One Inventory application.
- ☐ One branch.
- ☐ Two members.
- ☐ 500 products.
- ☐ 300 monthly transactions.
- ☐ Basic reports.
- ☐ Basic customer credit.
- ☐ Limited audit history.
- ☐ Limited imports or exports.

9. Standard Plan

- ☐ Standard plan exists.
- ☐ Monthly price is configured.
- ☐ Annual price is configured.
- ☐ Prices are stored in kobo.
- ☐ Currency is stored.
- ☐ Standard plan entitlements exist.
- ☐ Standard plan supports up to three owned organizations.
- ☐ Standard plan supports up to three branches per organization.
- ☐ Standard plan supports ten members per organization.
- ☐ Standard plan supports 5,000 products.
- ☐ Standard plan supports 5,000 monthly transactions.
- ☐ Standard plan supports Inventory.
- ☐ Standard billing interval is stored.
- ☐ Standard subscription status is stored.
- ☐ Standard entitlements are recalculated after activation.
- ☐ Standard usage is visible.
- ☐ Standard limits are checked server-side.

Standard upgrade

- ☐ Upgrade button is available to eligible owners.
- ☐ User can choose monthly or annual billing.
- ☐ Billing email is collected or confirmed.
- ☐ Paystack checkout is initialized server-side.
- ☐ Payment reference is created.
- ☐ User is redirected to Paystack.
- ☐ Frontend callback is not trusted as final payment confirmation.
- ☐ Backend verifies the payment.
- ☐ Webhook signature is verified.
- ☐ Webhook event ID is deduplicated.
- ☐ Payment record is created.
- ☐ Subscription is updated.
- ☐ Entitlements are activated.
- ☐ Trial state is ended.
- ☐ Organization status becomes active.

- ☐ User is redirected back to Inventory.
- ☐ User sees Standard limits immediately after confirmation.
- ☐ Upgrade event is audited.
- ☐ Upgrade notification is sent.

Expected final state:

```
selectedPlan = standard
checkoutStatus = completed
paymentStatus = success
subscriptionStatus = active
activePlan = standard
entitlementStatus = active
trialEnd = null
```

10. Billing Account

- ☐ One billing account is associated with the organization.
- ☐ Billing account owner is stored.
- ☐ Billing email is stored.
- ☐ Billing phone is optional.
- ☐ Billing currency is stored.
- ☐ Payment provider is stored.
- ☐ Paystack customer ID is stored if applicable.
- ☐ Billing account status exists.
- ☐ Billing account changes are audited.
- ☐ Billing account is not attached to individual employees.
- ☐ Workspace members do not need individual subscriptions.
- ☐ Billing owner notifications are configured.
- ☐ Billing permissions are separate from general membership.

Billing permissions

- ☐ `billing.view`.
- ☐ `billing.manage`.
- ☐ `billing.change_plan`.
- ☐ `billing.cancel`.
- ☐ `billing.resume`.
- ☐ `billing.view_invoices`.
- ☐ `billing.view_payments`.

- `[] billing.manage_payment_method.`
- `[] billing.export.`

11. Paystack Integration

- `[]` Paystack is the only active payment provider for the MVP.
- `[]` Provider keys are stored securely.
- `[]` Provider secrets are server-side only.
- `[]` Checkout initialization is server-side.
- `[]` Amount is validated server-side.
- `[]` Currency is validated server-side.
- `[]` Plan is validated server-side.
- `[]` Billing interval is validated server-side.
- `[]` Customer email is validated server-side.
- `[]` Payment reference is unique.
- `[]` Transaction verification is server-side.
- `[]` Webhook signature is verified.
- `[]` Provider event ID is deduplicated.
- `[]` Duplicate events are safely ignored.
- `[]` Payment failures are recorded.
- `[]` Payment renewals are recorded.
- `[]` Payment cancellations are recorded.
- `[]` Refunds or chargebacks are recorded when supported.
- `[]` Payment history cannot be silently edited.
- `[]` Payment records cannot be deleted by normal admins.
- `[]` Card numbers are never stored.
- `[]` Card security codes are never stored.
- `[]` Raw provider credentials are never logged.
- `[]` Raw webhook payloads are minimized or protected.
- `[]` Webhook failures are retryable.
- `[]` Webhook failures create operational alerts.

12. Subscription Lifecycle

- ☐ `trialing` status exists.
- ☐ `active` status exists.
- ☐ `past_due` status exists.
- ☐ `grace_period` status exists.
- ☐ `cancelled` status exists.
- ☐ `expired` status exists.
- ☐ `suspended` status exists.
- ☐ Trial-to-active transition works.
- ☐ Active-to-past-due transition works.
- ☐ Past-due-to-active transition works.
- ☐ Past-due-to-grace-period transition works.
- ☐ Grace-period-to-suspended transition works.
- ☐ Active-to-cancelled transition works.
- ☐ Cancelled-to-expired transition works.
- ☐ Renewal transition works.
- ☐ Cancellation effective date is stored.
- ☐ Current billing period is stored.
- ☐ Grace period end date is stored.
- ☐ Subscription state changes are audited.
- ☐ Subscription state is identical for user and superadmin dashboards.

Failed payments

- ☐ Payment failure notification is sent.
- ☐ Subscription becomes `past_due`.
- ☐ Grace period begins.
- ☐ Retry payment action is available.
- ☐ Billing owner receives warnings.
- ☐ New resource creation can be restricted.
- ☐ Existing data remains preserved.
- ☐ Read-only or limited mode is documented.
- ☐ Subscription can be restored after successful payment.
- ☐ Restoration is audited.
- ☐ User receives restoration notification.

13. Usage and Entitlements

- ☐ Central entitlement service exists.
- ☐ Entitlements are not hardcoded inside Inventory.
- ☐ Workspace limit is checked.
- ☐ Application limit is checked.
- ☐ Branch limit is checked.
- ☐ Member limit is checked.
- ☐ Product limit is checked.
- ☐ Transaction limit is checked.
- ☐ Storage limit is checked if implemented.
- ☐ Export limit is checked if implemented.
- ☐ API limit is checked if implemented.
- ☐ Usage counters exist.
- ☐ Usage counters are organization-scoped.
- ☐ Usage counters are application-scoped where required.
- ☐ Usage counters have a period.
- ☐ Usage counters are updated safely.
- ☐ Usage counters are idempotent.
- ☐ Usage warnings are shown at defined thresholds.
- ☐ Usage is visible to owners and billing managers.
- ☐ Usage is visible to superadmin.
- ☐ Entitlements are recalculated after plan changes.
- ☐ Entitlements are recalculated after payment confirmation.
- ☐ Entitlement mismatches are flagged.
- ☐ Unlimited limits use an explicit unlimited type.
- ☐ Limits are enforced on the backend.
- ☐ Frontend limits are informational only.

14. User Billing Experience

- ☐ Billing page exists.
- ☐ Current plan is displayed.
- ☐ Subscription status is displayed.
- ☐ Payment status is displayed.
- ☐ Trial dates are displayed.

- ☐ Current billing period is displayed.
- ☐ Next billing date is displayed.
- ☐ Billing interval is displayed.
- ☐ Amount is displayed.
- ☐ Currency is displayed.
- ☐ Usage summary is displayed.
- ☐ Plan limits are displayed.
- ☐ Upgrade button exists.
- ☐ Downgrade flow is planned or implemented.
- ☐ Cancel flow is planned or implemented.
- ☐ Resume flow is planned or implemented.
- ☐ Payment history is displayed.
- ☐ Invoice history is displayed.
- ☐ Payment failure banner exists.
- ☐ Trial ending warning exists.
- ☐ Limit-reached prompts exist.
- ☐ Upgrade prompts explain the current limitation.
- ☐ Billing actions require appropriate permissions.
- ☐ Billing changes require confirmation.
- ☐ Sensitive billing changes require re-authentication.
- ☐ Billing notifications are sent to owners or billing managers.

15. Downgrade and Cancellation

- ☐ Downgrade plan is supported or explicitly disabled.
- ☐ Downgrade is scheduled where possible.
- ☐ Current period end is respected.
- ☐ Conflicting resources are calculated.
- ☐ Excess organizations are identified.
- ☐ Excess applications are identified.
- ☐ Excess branches are identified.
- ☐ Excess members are identified.
- ☐ Excess products are identified.
- ☐ User can choose what to keep.
- ☐ User can archive excess resources.

- ☐ Data is not automatically deleted.
- ☐ Downgrade requires confirmation.
- ☐ Downgrade is audited.
- ☐ Cancellation date is displayed.
- ☐ Access remains active until cancellation takes effect.
- ☐ Cancellation reason can be collected.
- ☐ Cancellation notification is sent.
- ☐ Subscription can be resumed before expiry.
- ☐ Cancellation does not delete business history.

16. Superadmin Organization Access

Superadmin can read

- ☐ Organization list.
- ☐ Organization profile.
- ☐ Organization owner.
- ☐ Organization status.
- ☐ Organization creation date.
- ☐ Organization applications.
- ☐ Inventory activation status.
- ☐ Organization branches.
- ☐ Branch status.
- ☐ Organization members.
- ☐ Application members.
- ☐ Branch members.
- ☐ Roles.
- ☐ Permissions.
- ☐ Invitations.
- ☐ Onboarding progress.
- ☐ Billing account.
- ☐ Subscription status.
- ☐ Payment status.
- ☐ Payment history.
- ☐ Invoice history.
- ☐ Entitlements.

- ☐ Usage counters.
- ☐ Billing mismatches.
- ☐ Organization audit logs.
- ☐ Application audit logs.
- ☐ Branch audit logs.
- ☐ Support notes.
- ☐ Failed provisioning events.
- ☐ Failed webhooks.
- ☐ Account and organization activity summaries.

Superadmin may perform

- ☐ Suspend organization.
- ☐ Restore organization.
- ☐ Archive organization.
- ☐ Restore archived organization.
- ☐ Suspend Inventory.
- ☐ Restore Inventory.
- ☐ Suspend branch access.
- ☐ Restore branch access.
- ☐ Recalculate entitlements.
- ☐ Retry failed provisioning.
- ☐ Retry failed webhook processing.
- ☐ Extend a trial with a reason.
- ☐ Add a support note.
- ☐ Revoke organization member sessions.
- ☐ Export permitted organization data.
- ☐ Review billing mismatches.
- ☐ Mark a billing issue for support review.

Superadmin restrictions

- ☐ Cannot view passwords.
- ☐ Cannot view password hashes.
- ☐ Cannot set user passwords directly.
- ☐ Cannot view raw session tokens.
- ☐ Cannot view TOTP secrets.

- ☐ Cannot view provider secrets.
- ☐ Cannot view card details.
- ☐ Cannot silently change roles.
- ☐ Cannot silently edit sales.
- ☐ Cannot silently edit stock.
- ☐ Cannot silently edit purchases.
- ☐ Cannot delete audit logs.
- ☐ Cannot delete payment history.
- ☐ Cannot impersonate users in the MVP.
- ☐ Cannot access unrelated private security activity without permission.
- ☐ Cannot access personal data unnecessarily.
- ☐ Cannot make changes without audit records.
- ☐ Cannot make sensitive changes without confirmation.
- ☐ Cannot make high-risk changes without re-authentication.

The personal profile plan explicitly separates personal security and account data from workspace administration. Workspace administrators should manage access to a workspace, not another user's password, personal email, sessions, or private security settings.^[3]

17. Superadmin Confirmation Rules

Normal actions

- ☐ Confirmation modal is shown.
- ☐ Target organization is displayed.
- ☐ Action consequence is displayed.
- ☐ Cancel option is available.
- ☐ Success or failure is shown.
- ☐ Audit event is created.

Sensitive actions

- ☐ Confirmation is required.
- ☐ Reason is required.
- ☐ Recent admin authentication is required.
- ☐ Action is bound to the exact target.
- ☐ Confirmation token is short-lived.
- ☐ Confirmation token is single-use.

- ☐ Reuse is rejected.
- ☐ Confirmation mismatch is rejected.

High-risk actions

- ☐ TOTP is required.
- ☐ Confirmation phrase is required.
- ☐ Reason is required.
- ☐ High-severity audit event is created.
- ☐ Optional second-admin approval is considered.
- ☐ Notifications are sent to affected parties.

High-risk examples:

- ☐ Organization deletion.
- ☐ Ownership transfer.
- ☐ Entitlement override.
- ☐ Manual subscription change.
- ☐ Payment refund.
- ☐ Bulk export.
- ☐ Superadmin role change.
- ☐ Global application enablement.

18. Audit Logs

Audit log fields

- ☐ Actor ID.
- ☐ Actor type.
- ☐ Target organization.
- ☐ Target application.
- ☐ Target branch.
- ☐ Target user.
- ☐ Event type.
- ☐ Entity type.
- ☐ Entity ID.
- ☐ Severity.
- ☐ Before values where safe.
- ☐ After values where safe.

- ☐ Reason.
- ☐ Request ID.
- ☐ IP address.
- ☐ User agent.
- ☐ Timestamp.
- ☐ Safe metadata.

Organization events

- ☐ Organization created.
- ☐ Organization updated.
- ☐ Organization archived.
- ☐ Organization restored.
- ☐ Organization suspended.
- ☐ Organization deletion requested.
- ☐ Ownership transfer started.
- ☐ Ownership transferred.
- ☐ Settings changed.
- ☐ Branding changed.
- ☐ Contact changed.
- ☐ Currency changed.
- ☐ Organization export requested.

Billing events

- ☐ Plan selected.
- ☐ Checkout started.
- ☐ Checkout initialized.
- ☐ Payment verified.
- ☐ Payment failed.
- ☐ Subscription created.
- ☐ Subscription renewed.
- ☐ Plan changed.
- ☐ Trial started.
- ☐ Trial extended.
- ☐ Trial ended.
- ☐ Payment past due.

- ☐ Grace period started.
- ☐ Subscription cancelled.
- ☐ Subscription restored.
- ☐ Entitlements granted.
- ☐ Entitlements revoked.
- ☐ Limit reached.
- ☐ Webhook received.
- ☐ Webhook duplicated.
- ☐ Webhook failed.

Membership events

- ☐ Member invited.
- ☐ Invitation accepted.
- ☐ Invitation revoked.
- ☐ Role changed.
- ☐ Application access granted.
- ☐ Application access revoked.
- ☐ Branch access granted.
- ☐ Branch access revoked.
- ☐ Member suspended.
- ☐ Member restored.
- ☐ Member removed.
- ☐ Sessions revoked.

Audit restrictions

- ☐ Audit logs are append-only.
- ☐ Audit logs cannot be edited by users.
- ☐ Audit logs cannot be deleted by ordinary admins.
- ☐ Sensitive views are audited.
- ☐ Audit log access is permission-controlled.
- ☐ Audit logs are paginated.
- ☐ Audit logs are searchable.
- ☐ Audit logs are organization-scoped.
- ☐ Secrets are excluded.
- ☐ Raw tokens are excluded.

- ☐ Card data is excluded.
- ☐ Passwords are excluded.
- ☐ TOTP secrets are excluded.

19. Privacy and Data Protection

- ☐ Privacy policy is available.
- ☐ Terms of service are available.
- ☐ Data collection purposes are explained.
- ☐ Data minimization is applied.
- ☐ Organization data is separated from personal data.
- ☐ User personal phone is not exposed by default.
- ☐ User personal email is not editable by workspace admins.
- ☐ User personal security activity is not exposed to workspace admins.
- ☐ Personal data export is supported or planned.
- ☐ Organization data export is supported or planned.
- ☐ Account deletion behavior is documented.
- ☐ Organization deletion behavior is documented.
- ☐ Ownership transfer is required before deleting an owner account where appropriate.
- ☐ Historical business records are preserved where required.
- ☐ Deleted users can be anonymized in historical records where necessary.
- ☐ Payment records follow accounting retention requirements.
- ☐ Audit retention is defined.
- ☐ Verification tokens expire.
- ☐ Password-reset tokens expire.
- ☐ Uploaded import files have retention rules.
- ☐ Raw personal data is not unnecessarily copied.
- ☐ Bulk exports are restricted and audited.

20. Security Rules

- ☐ Authentication is required.
- ☐ Email verification is required for sensitive onboarding actions.
- ☐ Session validation occurs on every protected request.
- ☐ Organization context is resolved server-side.
- ☐ Product access is verified server-side.

- ☐ Branch access is verified server-side.
- ☐ Permissions are verified server-side.
- ☐ Rate limiting exists.
- ☐ Brute-force protection exists.
- ☐ Session revocation works.
- ☐ Removed members lose access.
- ☐ Suspended organizations lose restricted access.
- ☐ Expired subscriptions trigger restriction rules.
- ☐ Passwords are hashed securely.
- ☐ Passwords are never logged.
- ☐ Raw session tokens are not stored.
- ☐ Refresh tokens are hashed or securely managed.
- ☐ OAuth secrets remain server-side.
- ☐ Paystack secrets remain server-side.
- ☐ Webhook signatures are verified.
- ☐ Idempotency keys are used for retrievable writes.
- ☐ Duplicate payment processing is prevented.
- ☐ Duplicate organization creation is prevented.
- ☐ Duplicate invitations are prevented.
- ☐ Suspicious cross-organization access is logged.
- ☐ Error messages do not leak sensitive information.
- ☐ API responses are sanitized.
- ☐ Export permissions are enforced.
- ☐ Sensitive administrative actions require re-authentication.

21. Notifications

User notifications

- ☐ Organization created.
- ☐ Organization invitation received.
- ☐ Member joined.
- ☐ Member removed.
- ☐ Role changed.
- ☐ Inventory activated.
- ☐ Branch created.

- ☐ Branch access changed.
- ☐ Trial started.
- ☐ Trial ending.
- ☐ Payment initiated.
- ☐ Payment successful.
- ☐ Payment failed.
- ☐ Subscription changed.
- ☐ Subscription cancelled.
- ☐ Workspace restricted.
- ☐ Entitlements changed.
- ☐ Limit reached.

Notification channels

- ☐ In-app notifications.
- ☐ Email notifications.
- ☐ SMS only where explicitly enabled.
- ☐ WhatsApp only where officially supported.
- ☐ Security notifications cannot be fully disabled.
- ☐ Billing notifications go to billing owner.
- ☐ Non-critical notifications can be configured.

22. API and Backend

Request lifecycle

- ☐ Request ID assigned.
- ☐ Session authenticated.
- ☐ User loaded.
- ☐ Organization resolved.
- ☐ Membership verified.
- ☐ Application entitlement verified.
- ☐ Branch access verified.
- ☐ Permission verified.
- ☐ Input validated.
- ☐ Mutation executed.
- ☐ Audit event written.

- ☐ Notification sent if necessary.
- ☐ Sanitized response returned.

Required backend modules

- ☐ Workspaces.
- ☐ Workspace settings.
- ☐ Memberships.
- ☐ Invitations.
- ☐ Roles.
- ☐ Permissions.
- ☐ Applications.
- ☐ Branches.
- ☐ Billing accounts.
- ☐ Plans.
- ☐ Subscriptions.
- ☐ Payments.
- ☐ Billing events.
- ☐ Entitlements.
- ☐ Usage.
- ☐ Notifications.
- ☐ Audit logs.
- ☐ Superadmin actions.
- ☐ Support notes.

Required indexes

- ☐ Workspaces by owner.
- ☐ Workspaces by slug.
- ☐ Workspaces by status.
- ☐ Memberships by workspace.
- ☐ Memberships by user.
- ☐ Memberships by workspace and user.
- ☐ Memberships by user and status.
- ☐ Applications by key.
- ☐ Applications by status.
- ☐ Workspace applications by workspace.

- ☐ Workspace applications by workspace and product.
- ☐ Product memberships by workspace.
- ☐ Product memberships by workspace and user.
- ☐ Branches by workspace.
- ☐ Branches by workspace and status.
- ☐ Branches by workspace and product.
- ☐ Subscriptions by workspace.
- ☐ Payments by workspace.
- ☐ Billing events by provider event ID.
- ☐ Entitlements by workspace.
- ☐ Audit logs by workspace and created date.
- ☐ Audit logs by actor.

23. Testing Checklist

Organization tests

- ☐ User can create an organization.
- ☐ Unverified user cannot perform restricted creation.
- ☐ User cannot exceed ownership limit.
- ☐ Joined organization does not consume ownership limit.
- ☐ Trial limit is enforced.
- ☐ Duplicate creation is prevented.
- ☐ Owner membership is created.
- ☐ Default roles are created.
- ☐ Default settings are created.
- ☐ Inventory record is created.
- ☐ Primary branch is created.
- ☐ Audit event is created.
- ☐ Notification is created.
- ☐ Organization creation resumes safely after partial failure.

Billing tests

- ☐ Free Trial requires no payment.
- ☐ Trial dates are correct.
- ☐ Standard checkout initializes.
- ☐ Wrong payment amount is rejected.
- ☐ Wrong currency is rejected.
- ☐ Wrong reference is rejected.
- ☐ Failed payment changes subscription state.
- ☐ Successful payment activates Standard.
- ☐ Frontend callback alone does not activate access.
- ☐ Webhook signature is rejected when invalid.
- ☐ Duplicate webhook is ignored.
- ☐ Duplicate payment is not created.
- ☐ Entitlements are recalculated.
- ☐ User and superadmin state match.
- ☐ Grace period works.
- ☐ Cancellation works.
- ☐ Downgrade conflict detection works.

Access tests

- ☐ Organization members can be identified.
- ☐ Non-members are rejected.
- ☐ Inventory members can access Inventory.
- ☐ Organization members without Inventory access are rejected.
- ☐ Branch access is enforced.
- ☐ Suspended users are rejected.
- ☐ Suspended organizations are restricted.
- ☐ Archived organizations are restricted.
- ☐ Cross-organization IDs are rejected.
- ☐ Forged roles are rejected.
- ☐ Forged application keys are rejected.
- ☐ Removed members lose access.
- ☐ Session revocation works.

Superadmin tests

- ☐ Superadmin can search organizations.
- ☐ Superadmin can inspect billing.
- ☐ Superadmin can inspect applications.
- ☐ Superadmin can inspect branches.
- ☐ Superadmin can inspect teams.
- ☐ Superadmin can inspect onboarding.
- ☐ Superadmin can inspect usage.
- ☐ Superadmin can inspect audit history.
- ☐ Unauthorized admin actions are rejected.
- ☐ Sensitive actions require confirmation.
- ☐ High-risk actions require re-authentication.
- ☐ Admin reason is stored.
- ☐ Admin action is audited.
- ☐ Secrets are not displayed.
- ☐ Business records cannot be directly edited.
- ☐ Audit logs cannot be changed.

24. Launch Rules and Regulations

- ☐ Terms of Service are published.
- ☐ Privacy Policy is published.
- ☐ Billing terms are published.
- ☐ Trial terms are clearly explained.
- ☐ Renewal behavior is clearly explained.
- ☐ Cancellation behavior is clearly explained.
- ☐ Refund policy is clearly explained.
- ☐ Payment failure behavior is clearly explained.
- ☐ Grace period behavior is clearly explained.
- ☐ Data retention policy is documented.
- ☐ Account deletion policy is documented.
- ☐ Organization deletion policy is documented.
- ☐ Export policy is documented.
- ☐ Support contact is available.
- ☐ Pricing is displayed accurately.

- ☐ Currency is displayed accurately.
- ☐ Taxes and fees are explained where applicable.
- ☐ Paystack terms are respected.
- ☐ No card information is stored by Orvionhub.
- ☐ User consent is recorded.
- ☐ Marketing consent is separate from required terms.
- ☐ Security notifications remain enabled.
- ☐ Personal data collection is minimized.
- ☐ Access to personal data is limited by purpose.
- ☐ Sensitive administrative access is logged.
- ☐ Nigerian legal and tax requirements are reviewed before making compliance claims.
- ☐ No unsupported claim of full tax or e-invoicing compliance is made.

25. Final Definition of Done

Organization and billing are ready for MVP when:

- ☐ A verified user can create an organization.
- ☐ The organization receives its own billing context.
- ☐ Free Trial can be started without payment.
- ☐ Inventory is activated as the only available application.
- ☐ A primary branch is created.
- ☐ Inventory onboarding can be completed or resumed.
- ☐ Standard upgrade works through Paystack.
- ☐ Payment is verified server-side.
- ☐ Webhooks are verified and deduplicated.
- ☐ Entitlements are recalculated automatically.
- ☐ Usage limits are enforced server-side.
- ☐ Billing status is consistent everywhere.
- ☐ Branch access is isolated.
- ☐ Team membership is permission-based.
- ☐ Superadmin can inspect the entire organization lifecycle.
- ☐ Superadmin actions are confirmed and audited.
- ☐ Sensitive secrets remain inaccessible.
- ☐ Historical business data is preserved.
- ☐ Failed payments do not immediately destroy data.

- [] Downgrades do not silently delete resources.
- [] Cross-tenant access is blocked.
- [] User and superadmin workflows have passed integration testing.

*
**

1. docs/Orviohub Pricing Implementation Plan.pdf
2. docs/Workspace Management Implementation Plan.pdf
3. docs/User Personal Profile Management Plan.pdf